

Executive Summary

ده تقرير Audit كامل لمشروع Laravel API الخاص بـ ebook store. التقرير معمول بصيغة مناسبة للمراجعة من CTO و Lead Backend و Engineers و Security Team و DevOps Team. الفحص الحالي بيبيّن إن المشروع فيه أساس MVP واضح، لكنه غير جاهز للإنتاج بسبب مشاكل حرجة في deployment readiness، testing، dependency vulnerabilities، webhook security، payment flow، و API consistency. `audit-report.md`: المطلوبة artifacts اتعدل أثناء إنشاء التقرير. الملفات اللي اتعملت هي source code فقط. مفيش Audit أهم نقطة: التقرير ده لو التولنج متاح PDF وملف.

Scope

- Project path: `/Users/omarkhaled/Projects/ebook-store/ebook-store-api`

Date: 2026-06-03

Runtime timezone: Africa/Cairo

Evidence Collected

- ملفات البيئة، `composer.json`، `composer.lock`، `bootstrap/`، `tests/`، `resources/`، `config/`، `database/`، `routes/`، `app/` تم فحص المتاح CI وملفات النشر.
 - Evidence: `php artisan route:list -v`، `php artisan test`، `composer validate`، `composer check-platform-reqs`، `composer audit --locked`، `composer outdated --direct --locked`، و `vendor/bin/pint --test`.
 - `composer audit --locked` 9 لقي 7 advisories بتاريخ الفحص لقي 9 `composer audit --locked` منها `laravel/framework` و `symfony/mime` High severity.
 - فقط، فده مش معناه إن النظام متغطي وظيفيا أو أمينا scaffold tests نجح، بس الموجود 2 `php artisan test`.
 - `vendor/bin/pint --test` فشل على ملفات كثير في `app/`، `routes/`، `database/`، و `config/`.
- مفيش Docker files ولا CI/CD/deployment files واضحة في المشروع حسب الفحص الحالي.

Findings Summary

Count	Severity
3	Critical
10	High
18	Medium
4	Low
35	Total

Architecture Audit

لسه checkout/payment/download/admin upload زى domain workflows الأساسي، بس الـ Laravel structure المشروع ماشي على لكنها مش متوصلة فعليا. support: Money, Enums, Policies, Resources, فيه محاولات جزئية لإدخال. routes أو controllers متكتبة مباشرة في end-to-end. اتحسننت وهي لسه مش شغالة architecture إن الفريق يفتكر إن risk بشكل كامل، وده يعمل controllers بالـ

Finding ID: AUD-017

:Severity

Medium

:Category

Architecture / Separation of Concerns

:Location

Controllers and route closures

:File

app/Http/Controllers/OrderController.php

:Line

23-50

:Issue Title

Business logic كثير جوه controllers/routes

:Problem Description

email verification logic, Ordering, payment initiation, webhook processing, download generation, admin upload موجودين مباشرة في controllers أو closures.

:Root Cause

مفيش application service/action layer واضح للـ domain workflows.

:Technical Impact

صعوبة testing, تكرار checks, وزيادة regression risk.

:Business Impact

أي تغيير في payment/checkout هيبقى أبطأ وأخطر.

:Recommended Solution

استخدم services/actions متخصصة: [CheckoutService](#), [PaymentInitiationService](#), [PaymobWebhookProcessor](#), [DownloadTokenService](#).

:Implementation Guidance

ابدأ بال payment/order flows لأنها الأعلى خطورة، واكتب unit tests للخدمات.

:Estimated Fix Effort

High

:Priority

Short-Term

Finding ID: AUD-018

:Severity

Medium

:Category

Laravel Best Practices / Authorization

:Location

Policies/resources worktree

:File

app/Policies/OrderPolicy.php

:Line

1

:Issue Title

Resources و Policies موجودة جزئيا لكن مش متوصلة بال controllers

:Problem Description

raw arrays/models لسه بترجع controllers لكن في worktree. في [app/Http/Resources](#) و [app/Policies](#) فيه ملفات جديدة تحت يدوية checks وتعمل.

:Root Cause

Refactor جزئي غير مكتمل ومش متصل بال route/controller layer.

:Technical Impact

Authorization و response serialization مش موحدين، ويمكن يبقى فيه إحساس كاذب إن السياسات شغالة.

:Business Impact

مراجعة security أصعب، و API contract أقل استقرارا.

:Recommended Solution

يا إما تكمل wiring رسمي لك policies/resources, يا إما تشيل refactor الجزئي من branch audit.

:Implementation Guidance

JsonResource. ب raw responses واستبدل. controllers. في middleware/policies أو authorize() استخدم

:Estimated Fix Effort

Medium

:Priority

Short-Term

Finding ID: AUD-029

:Severity

Medium

:Category

Source Control / Release Risk

:Location

Working tree

:File

N/A

:Line

N/A

:Issue Title

Working tree فيها تغييرات جزئية وملفات untracked

:Problem Description

بالإضافة لـ app/Enums, app/Policies, app/Http/Resources جديدة زي directories متغيرة و source files يعرض git status --short load-test.js.

:Root Cause

فيه partial refactor/security changes غير مكتملة أو غير committed.

:Technical Impact

صعب تعرف baseline الحقيقي، ويمكن deploy يضم نصف حل أو ملفات dev.

:Business Impact

مخاطر release غير متوقعة ومراجعة أمنية أقل وضوحا.

:Recommended Solution

اعمل branch واضح، راجع diff، افصل audit artifacts عن source changes، وامنع untracked dev scripts من الدخول release.

:Implementation Guidance

ثابت commit من CI clean build و،code review، git diff، git status، deploy: قبل أي

:Estimated Fix Effort

Low

:Priority

Immediate

Finding ID: AUD-033

:Severity

Low

:Category

Domain Modeling / Type Safety

:Location

Models

:File

app/Models/Order.php

:Line

22-25

:Issue Title

status, role, money, booleans نقصة لـ Casts/enums

:Problem Description

جديدة في enums فيه. model بشكل واضح في castمت Ebook.price/is_published، User.role string، Order.status string، لكن مش مستخدمة worktree.

:Root Cause

Domain model لسه بسيط ومش بيستخدم typed invariants.

:Technical Impact

مقارنات strings متكررة وأخطاء typo محتملة.

:Business Impact

Maintenance أصعب مع توسع الحالات.

:Recommended Solution

استخدم PHP backed enums و casts لل money/booleans/status/role.

:Implementation Guidance

compatibility مع Laravel version. بعد مراجعة casts فعليا بال UserRole و OrderStatus اربط

:Estimated Fix Effort

Medium

:Priority

Long-Term

Finding ID: AUD-034

:Severity

Low

:Category

Architecture / Repositories

:Location

Project structure

:File

app/Services/PaymobService.php

:Line

7

:Issue Title

Repository/query layer مش موجود رغم تكرار query patterns

:Problem Description

المشروع مفيهوش repository/query objects. ده مش مشكلة لوحده في مشروع صغير، لكن فيه query patterns متكررة لل orders/downloads/ebooks.

:Root Cause

الاعتماد المباشر على Eloquent داخل controllers/services.

:Technical Impact

مع التوسع، authorization conditions و filters هتتكرر.

:Business Impact

سرعة التطوير ممكن تقل مع زيادة features.

:Recommended Solution

ماتضيفش repository عام بدون داعي، لكن اعمل query objects/scopes للأماكن المتكررة فعلا.

:Implementation Guidance

admin order filters. لا query object و published, pendingForUser, paidForUser زي scopes ابدأ بـ

:Estimated Fix Effort

Low

:Priority

Long-Term

Laravel Best Practices Audit

Controllers فيها validation و business logic و response formatting في نفس المكان. FormRequests موجودة لبعض flows، لكن admin ebook upload لسه Policies/Resources inline. مش مستخدمة فعليا. Exception handler فاضي. Pint فاشل. ده معناه إن المشروع محتاج standardization قبل أي production push.

Finding ID: AUD-012

:Severity

Medium

:Category

Error Handling / Information Disclosure

:Location

Payment and download controllers

:File

app/Http/Controllers/PaymentController.php

:Line

77-81

:Issue Title

API responses بتكشف exception messages للمستخدم

:Problem Description

PaymentController يرجع \$e->getMessage()، وDownloadController يرجع exception message من service.

:Root Cause

مفیش centralized JSON error rendering أو exception abstraction.

:Technical Impact

ممکن تفاصيل داخلية عن provider/storage/business rules تظهر للعميل.

:Business Impact

بتسهل enumeration/debugging للمهاجم ويتقلل polish بتاع API.

:Recommended Solution

ارجع client-safe messages وسجل التفاصيل داخليا.

:Implementation Guidance

bootstrap/app.php موحد في grender وPaymentProviderException زي custom exceptions اعمل

:Estimated Fix Effort

Low

:Priority

Short-Term

Finding ID: AUD-020

:Severity

Medium

:Category

Error Handling / Observability

:Location

Bootstrap exception handler

:File

bootstrap/app.php

:Line

21-23

:Issue Title

Exception handling المركزي فاضی

:Problem Description

domain exceptions. لا custom rendering أو correlation IDs موحّد أو JSON error envelope فاضي، ومغيش `withExceptions`

:Root Cause

الاعتماد على defaults في API backend.

:Technical Impact

Errors هتطلع inconsistent، والمراقبة/debugging أصعب.

:Business Impact

وقت أطول لحل incidents وتجربة API أقل احترافية.

:Recommended Solution

اعمل logging context، centralized JSON exception rendering، و integration مع monitoring.

:Implementation Guidance

عرف renderers ل validation/auth/payment/storage exceptions، وضيف request ID في كل response/log.

:Estimated Fix Effort

Medium

:Priority

Short-Term

Finding ID: AUD-023

:Severity

Low

:Category

Code Quality / Standards

:Location

Pint formatting

:File

routes/api.php

:Line

1

:Issue Title

backend فشل على أغلب ملفات `--test vendor/bin/pint`

:Problem Description

Pint لقی formatting issues فی config, controllers, models, requests, services, migrations, routes.

:Root Cause

مغیش formatter gate فی workflow/CI.

:Technical Impact

Diff noise, صعوبة review, احتمال style drift.

:Business Impact

Maintenance cost أعلى على الفريق.

:Recommended Solution

شغل Pint وثبته فی CI ك check required.

:Implementation Guidance

اعمل formatting commit منفصل بعد functional/security fixes عشان يبقى review واضح.

:Estimated Fix Effort

Low

:Priority

Short-Term

Finding ID: AUD-024

:Severity

Medium

:Category

API Validation / Filtering

:Location

Admin order listing

:File

app/Http/Controllers/Admin/AdminOrderController.php

:Line

14-18

:Issue Title

Admin order filter غير متحقق منه status

:Problem Description

enum validation أو FormRequest من غير where يستخدم مباشرة في \$request->status.

:Root Cause

Filtering اضافة inline من غير validation layer.

:Technical Impact

invalid ممكن ترجع نتائج غلط أو تعمل API contract مش واضح.

:Business Impact

Admin reporting غير موثوق.

:Recommended Solution

max. per_page المسموحة وحدد statuses بقائمة FormRequest استخدم.

:Implementation Guidance

enum. أو Rule::in(["pending", "paid", "failed"]) استعمال.

:Estimated Fix Effort

Low

:Priority

Short-Term

Finding ID: AUD-035

:Severity

Low

:Category

Dependency Hygiene

:Location

Composer direct dependencies

:File

composer.json

:Line

10-12

:Issue Title

Direct dependencies محتاجة مراجعة production necessity

:Problem Description

الأفضل تقلل الأدوات production security posture ده شائع أحياناً، لكن في require-dev مش require موجود في laravel/tinker التفاعلية.

:Root Cause

Composer skeleton defaults متساين من غير dependency minimization review.

:Technical Impact

سطح tooling أكبر في production artifact.

:Business Impact

مخاطر تشغيل/debug غير مقصود أقل لو اتشالت من production.

:Recommended Solution

require-dev ولو لا انقله ل production، مطلوب laravel/tinker راجع هل

:Implementation Guidance

production. في بيئة شبيهة بال smoke test composer install --no-dev بعد النقل شغل

:Estimated Fix Effort

Low

:Priority

Long-Term

API Audit

بترجع endpoints، raw paginator، endpoints بترجع endpoints مش موحدة، في responses وده كويس كبداية. لكن v1 prefix عنده API الـ واضح، ومفیش throttling مفیش، implemented متسجلة ومش endpoints مباشرة. كمان فيه model بترجع endpoints، arrays، pagination list endpoints في بعض.

Finding ID: AUD-006

:Severity

High

:Category

API Security / Abuse Protection

:Location

API routes

:File

routes/api.php

:Line

88-103 ,58-61 ,24-25

:Issue Title

مفیش rate limiting واضح على auth و public write endpoints

:Problem Description

مش Routes زي `auth/login`, `auth/register`, `messages`, `payments/initiate`, `downloads/generate`, و `auth/resend-verification` route-specific throttles. ظاهر عليها

:Root Cause

ال API متساب على defaults من غير named limiters حسب نوع الخطر.

:Technical Impact

Brute force, spam, email abuse, payment provider abuse, DoS أسهل.

:Business Impact

تكلفة تشغيل أعلى، سمعة سيئة للرسائل، ومخاطر account takeover.

:Recommended Solution

حساس route لكل `throttle:*` وطبق service provider في rules `RateLimiter` ضيف

:Implementation Guidance

مثلا login يبقى IP/secret provider per webhook, payment/download per user, IP/contact message per email, monitoring مع

:Estimated Fix Effort

Low

:Priority

Immediate

Finding ID: AUD-009

:Severity

High

:Category

API Correctness / Laravel Routing

:Location

:File

routes/api.php

:Line

44

:Issue Title

Route::apiResource("orders") controller مش موجودة في endpoints ييسجل

:Problem Description

AdminOrderController فيه index() لكن يسجل apiResource store, show, update, و destroy. route:list انهم registered.

:Root Cause

استخدام resource routing قبل تنفيذ كل methods.

:Technical Impact

Requests لـ endpoints دي هتودي ل runtime errors أو 500، وده بيكسر admin API contract.

:Business Impact

Admin dashboard ممكن يفشل في production، وده بيطأ operations والدعم.

:Recommended Solution

استخدم validation/policies مع methods أو نفذ باقي ["index"] ->only استخدم

:Implementation Guidance

اكتب feature tests لكل admin order route عشان route contract يبقى ثابت.

:Estimated Fix Effort

Low

:Priority

Immediate

Finding ID: AUD-015

:Severity

Medium

:Category

Performance / API Design

:Location

:File

app/Http/Controllers/DashboardController.php

:Line

12-17

:Issue Title

Endpoints بترجع collections غير paginated

:Problem Description

pagination من غير `get()` يستخدموا `ContactMessageController@index` و `DashboardController@purchases`

:Root Cause

مفيش API pagination policy موحدة.

:Technical Impact

Memory usage وحجم response هيزيدوا مع الوقت.

:Business Impact

بطء dashboard/admin inbox وتجربة سيئة.

:Recommended Solution

حسب الحالة cursor pagination أو `paginate()` استخدم

:Implementation Guidance

consistent. meta بحد أقصى وارجع `per_page` حدد

:Estimated Fix Effort

Low

:Priority

Short-Term

Finding ID: AUD-016

:Severity

Medium

:Category

Authentication / Email Verification

:Location

:File

routes/api.php

:Line

67-86

:Issue Title

Email verification route `auth:sanctum` داخل `env()` ويستخدم

:Problem Description

يمكن يفشل. bearer token من غير browser من email link فالمستخدم اللي يفتح. auth middleware جوه signed verification route الـ
مباشرة `env("FRONTEND_URL")` يستخدم redirect كمان

:Root Cause

Email verification تعمل ك closure داخل routes بدل controller/config-driven flow.

:Technical Impact

Config cache ممكن يخلي `env()` unreliable. overification UX ممكن يتكسر.

:Business Impact

مستخدمين مش هيعرفوا يفعّلوا حساباتهم بسهولة، وده يقلل conversion.

:Recommended Solution

استخدم config key للـ frontend URL وخلي signed verification route متاحة بدون bearer auth مع signature check.

:Implementation Guidance

انقل logic ل controller واستخدم Laravel verification conventions واختبارات signed URLs.

:Estimated Fix Effort

Medium

:Priority

Short-Term

Finding ID: AUD-030

:Severity

Medium

:Category

Abuse Protection / Public Forms

:Location

Contact message endpoint

:File

app/Http/Requests/StoreContactMessageRequest.php

:Line

25-29

:Issue Title

Contact form مفيهوش spam controls أو max length للرسالة

:Problem Description

message required string من غير max, throttle/captcha/honeypot. route public من غير

:Root Cause

Public write endpoint تعمل minimal validation بس.

:Technical Impact

يمكن large payload abuses و spamy DB bloat.

:Business Impact

Admin inbox يبقى غير قابل للاستخدام وتكلفة تخزين/دعم أعلى.

:Recommended Solution

ضيف rate limit, max length, وربما captcha/honeypot حسب traffic.

:Implementation Guidance

لو مطلوب privacy-aware بشكل IP/user agent وتسجيل, throttle per IP, max 5000. message مثلا

:Estimated Fix Effort

Low

:Priority

Short-Term

Database Audit

ده غير orders. على cascade بيعمل ebooks مهمة. أخطر نقطة إن حذف indexes و constraints بسيطة وواضحة، لكن ناقصة migrations الـ لازم يفضل محفوظ purchase history لأن digital goods مناسب لنظام بيع.

:Severity

High

:Category

Data Integrity / Audit Trail

:Location

Ebook deletion and order FK behavior

:File

database/migrations/2026_05_14_122830_create_orders_table.php

:Line

17

:Issue Title

حذف ebook يعمل cascade delete لل orders المرتبطة

:Problem Description

المرتبطه purchase history/downloads فعليا، فكل ebook يمحذف `AdminEbookController@destroy` عليه `cascadeOnDelete()` ممكن تختفى.

:Root Cause

استخدام hard delete في domain محتاج audit/history retention.

:Technical Impact

فقدان financial records و entitlement records، وصعوبة support/reconciliation.

:Business Impact

مخاطر محاسبية وقانونية، ومستخدمين ممكن يفقدوا إثبات الشراء.

:Recommended Solution

استخدم soft deletes أو archive/unpublish بدل delete، وامنع حذف ebook عليه paid orders.

:Implementation Guidance

snapshot title/price. محفوظة مع orders وسبي، archived at أو deleted at ضيف

:Estimated Fix Effort

Medium

:Priority

Immediate

:Severity

High

:Category

Database Integrity

:Location

Orders and downloads migrations

:File

database/migrations/2026_05_14_122830_create_orders_table.php

:Line

18-19

:Issue Title

downloads.order_id ولا provider IDs على unique constraints مفيش

:Problem Description

مش فرضى DB لكن hasOne بتقول Model relation unique. مش downloads.order_id و paymob_transaction_id, paymob_order_id ده.

:Root Cause

Business invariants متساين في application layer بس.

:Technical Impact

Duplicate transactions/download tokens و ambiguous webhook matching ممكن يحصلوا.

:Business Impact

Entitlement mistakes و payment reconciliation صعب.

:Recommended Solution

ضيف unique indexes مناسبة مع nullable handling حسب MySQL. وراجع existing data قبل migration.

:Implementation Guidance

order واحد لكل token لو فعلا unique. وdownloads.order_id unique. وpaymob_transaction_id وpaymob_order_id

:Estimated Fix Effort

Medium

:Priority

Immediate

:Severity

Medium

:Category

Database Performance

:Location

Migrations and query patterns

:File

database/migrations/2026_05_14_122820_create_ebooks_table.php

:Line

24-25

:Issue Title

Missing indexes للاستعلامات المتكررة

:Problem Description

indexes مش عاملة migrations لكن `is_read` و `expires_at`, `paymob_order_id`, `user_id`, `status`, `is_published` الاستعلامات بتفلتر على كفاية.

:Root Cause

Schema اتعملت MVP بدون query-plan review.

:Technical Impact

مع زيادة البيانات، list endpoints/webhooks/downloads هتبقى أبطأ وتضغط DB.

:Business Impact

Latency أعلى وتجربة شراء/تحميل أضعف.

:Recommended Solution

ضيف composite indexes مبنية على query patterns.

:Implementation Guidance

أمثلة: `ebooks(is_published, created_at)`, `orders(user_id, status, created_at)`, `orders(paymob_order_id)`, `downloads(user_id, expires_at)`, `contact_messages(is_read, created_at)`.

:Estimated Fix Effort

Medium

:Priority

Security Audit

فيه security gaps حرجة في webhooks logging, storage exposure runtime, dependencies, rate limiting, mass assignment, credentials, download token lifecycle, دي نقاط لازم تتقفل قبل production.

Finding ID: AUD-001

:Severity

Critical

:Category

Security / DevOps / Storage

:Location

Generated filesystem routes and private storage disk

:File

config/filesystems.php

:Line

33-38

:Issue Title

Private storage عن طريق route table لسه ظاهر في `storage/{path}`

:Problem Description

GET لسه بتعرض `php artisan route:list -v` نتيجة `local disk` لـ `serve => false` الحالي بيحط `config/filesystems.php` رغم إن ممكن يفضل `cached routes/config` أو `runtime` ده معناه إن `FilesystemServiceProvider` من `PUT storage/{path}` و `storage/{path}` `direct serving` مفعل private storage.

:Root Cause

`serve` تم توليده قبل تعديل `route` أو `cached route/config` وغالباً بسبب `runtime route table` وال `source config` فيه عدم اتساق بين.

:Technical Impact

الخاص بال `authorization flow` وده بيكسر `DownloadController` مش داخل `route` ممكن تتشاف أو تتعامل من `storage/app/private` ملفات `download token`.

:Business Impact

تسريب ebooks مدفوعة أو ملفات خاصة ممكن يسبب خسارة مباشرة وثقة أقل ومخاطر قانونية.

:Recommended Solution

private disk مباشر لا route واقفل أي، deploy pipeline في cache امسح وابن، runtime متعطّل فعليا في `serve` أتأكد إن

:Implementation Guidance

أو `Storage::download()` خليك مع `config:clear, route:clear, config:cache, route:cache` بعد `php artisan route:list -v` راجع `signed controller endpoint` على `serve` بس للملفات الخاصة، وماتفعّلش

:Estimated Fix Effort

Medium

:Priority

Immediate

Finding ID: AUD-002

:Severity

Critical

:Category

Security / Logging / Payments

:Location

Paymob webhook verification middleware

:File

app/Http/Middleware/VerifyPaymobWebhook.php

:Line

61-70 , 15-20

:Issue Title

Webhook logs بتسجل `hmac_secret` و payment payload كامل

:Problem Description

logs دي أسرار وبيانات دفع حساسة مينفعش تدخل `full_data` و `concat`, `computed`, `received_hmac`, `hmac_secret` الكود ببسجل

:Root Cause

Debug logging اتساب في middleware حساس بدون redaction أو production guard.

:Technical Impact

أي حد عنده log access يقدر يشوف secret أو يعيد بناء توقيع HMAC، وكمان ممكن تظهر بيانات `card/source metadata`.

:Business Impact

اختراق logs ممكن يتحول لاختراق payment flow، وده يعرض الشركة لمخاطر `fraud` و `compliance`.

:Recommended Solution

status, و `transaction_id`, `order.id` آمنة زي identifiers وسجل بس ، secret/full payload logging امسح

:Implementation Guidance

logs. مش بيظهر في `hmac_secret` يتأكد إن automated test ضيف secrets. من غير failure logs وخلي structured logs masked استخدم

:Estimated Fix Effort

Low

:Priority

Immediate

Finding ID: AUD-005

:Severity

High

:Category

Dependency Security

:Location

Composer locked dependencies

:File

composer.lock

:Line

5232 ,4503 ,4252 ,4172 ,4068 ,3988 ,1057

:Issue Title

security advisories لقي 9 `composer audit --locked`

:Problem Description

advisories الفحص الحالي لقي `laravel/framework`, `symfony/http-foundation`, `symfony/http-kernel`, `symfony/mailer`, `symfony/mime`, `symfony/polyfill-intl-idn`, و `symfony/routing`.

:Root Cause

بيقول 13.13.0 متاح direct outdated على 13.9.0 بينما `laravel/framework` locked قديم نسبيا lock file الـ

:Technical Impact

التطبيق معرض لثغرات معروفة، منها CRLF/email injection و SMTP/header injection و routing/url issues.

:Business Impact

:Recommended Solution

بعد التحديث composer audit --locked و regression tests بأسرع وقت وشغل Laravel/Symfony patches حدّ

:Implementation Guidance

full test suite منفصل، وبعدها branch في composer update laravel/framework symfony/* --with-all-dependencies استخدم
auth/payment/email. لا smoke tests

:Estimated Fix Effort

Medium

:Priority

Immediate

Finding ID: AUD-007

:Severity

High

:Category

Authorization / Mass Assignment

:Location

User model and register validation

:File

app/Models/User.php

:Line

16

:Issue Title

email_verified_at و role ل mass assignment بيسمح User model

:Problem Description

حاليا controller صحيح. 23 line على validation في role بيقبل RegisterRequest كمان. email_verified_at و role فيه #[Fillable]
نفسه خطر للمستقبل model بس، user على role بييجر

:Root Cause

خلط admin-managed fields مع user-managed fields في fillable.

:Technical Impact

بالغلط verified state أو admin ممكن يدي update() أو User::create(\$request->validated()) مستقبلي يستخدم endpoint أي

:Business Impact

Privilege escalation أو bypass email verification.

:Recommended Solution

admin-only service/policy في role وخلي تغيير، public fillable من email_verified_at و role شيل

:Implementation Guidance

اعمل tests تثبت إن register/profile update ماينفعش يغير role أو verification state مباشرة.

:Estimated Fix Effort

Low

:Priority

Immediate

Finding ID: AUD-008

:Severity

High

:Category

Security / Secrets / Test Data

:Location

Seeder and load test script

:File

database/seeder/DatabaseSeeder.php

:Line

21-32

:Issue Title

Admin/User seeded credentials ضعيفة ومكررة في load-test.js

:Problem Description

credentials hardcoded بيحط نفس load-test.js و passpass بكلمة سر user@example.com و admin@example.com بيخلق Seeder

:Root Cause

بيانات dev/test مش مفصولة بوضوح عن production seeding و load testing script فيه secrets ثابتة.

:Technical Impact

لو seeder اتشغل في staging/production أو الملف اتشارك، takeover بسيط جدا.

:Business Impact

اختراق admin account ممكن يدي تحكم كامل في ebooks/orders.

:Recommended Solution

خلي seeders dev-only، واستخدم env-generated one-time admin credentials أو command آمن.

:Implementation Guidance

افصل LocalDatabaseSeeder عن production، وحط guard app()->environment("local", "testing").

:Estimated Fix Effort

Low

:Priority

Immediate

Finding ID: AUD-027

:Severity

Medium

:Category

Session / Cookie Security

:Location

Session config and .env

:File

config/session.php

:Line

202 ,172 ,50

:Issue Title

Session encryption/secure cookie مش مفروضين افتراضيا

:Problem Description

review كويس لبعض الحالات لكن محتاج lax SameSite default. SESSION_SECURE_COOKIE مش متحدد و env، في SESSION_ENCRYPT=false مع SPA domain.

:Root Cause

Production session policy مش محددة في repo.

:Technical Impact

Cookies ممكن تتقل بدون secure flag لو config غلط، وencrypted session payload مش.

:Business Impact

مخاطر session compromise أعلى.

:Recommended Solution

في production استخدم HTTPS-only secure cookies وsession encryption حسب architecture.

:Implementation Guidance

CORS/CSRF setup، وSESSION_DOMAIN، SANCTUM_STATEFUL_DOMAINS، راجع SESSION_SECURE_COOKIE=true، حدد

:Estimated Fix Effort

Low

:Priority

Short-Term

Finding ID: AUD-031

:Severity

Medium

:Category

Download Security / Race Conditions

:Location

Download token service

:File

app/Services/DownloadService.php

:Line

24-33

:Issue Title

Download token recreation مش transactional ومفیش single-use enforcement

:Problem Description

expiry. قبل reuse بس مش بيمنع downloaded_at بيعلم stream، وlock، أو transaction قديم وتنشئ جديد من غير token الخدمة بتحذف

:Root Cause

Token lifecycle business rules مش محددة في DB/service بشكل قوي.

:Technical Impact

Race conditions أو multiple valid downloads حسب التوقيت، و token reuse خلال 24 ساعة.

:Business Impact

مشاركة روابط تحميل مدفوعة ممكن تزيد.

:Recommended Solution

حدد policy: single-use أو limited-use، وطبقها transactionally.

:Implementation Guidance

concurrent requests مطلوب، واختبر single-use لو `downloaded_at` و `check`، و `order/download` على `row lock` استخدم.

:Estimated Fix Effort

Medium

:Priority

Short-Term

Performance Audit

provider calls synchronous، pagination بدون `get()` كفاية، فيه indexes مفيش: scalable الأداء حاليا مقبول لأن المشروع صغير، لكن مش فعليه `queue jobs` ومفيش.

Finding ID: AUD-011

:Severity

High

:Category

Reliability / External Integrations

:Location

Paymob service

:File

app/Services/PaymobService.php

:Line

23-24, 37-50, 66-74

:Issue Title

Paymob HTTP calls من غير timeout أو retry أو circuit handling

:Problem Description

كل `Http::post()` calls `timeout()`, `connectTimeout()`, `retry()` أو provider-specific error mapping.

:Root Cause

Integration service معمول بشكل مباشر وبسيط من غير resilience patterns.

:Technical Impact

API request ممكن يعلق أو يفشل مؤقتا من غير `retry`، وممكن يضغط PHP workers.

:Business Impact

Checkout failures، abandoned purchases، ودعم عملاء أكثر.

:Recommended Solution

تضيف timeouts قصيرة، retries محسوبة، logging آمن، و `job/reconciliation fallback`.

:Implementation Guidance

داخلية آمنة exceptions مع `Http::timeout(10)->connectTimeout(3)->retry(2, 200)` مثلا.

:Estimated Fix Effort

Medium

:Priority

Short-Term

Finding ID: AUD-021

:Severity

Medium

:Category

Queues / Scalability

:Location

Queue configuration and app behavior

:File

config/queue.php

:Line

16-45

:Issue Title

Queue infrastructure موجودة لكن مفيش custom Jobs ولا async payment/email workflows

:Problem Description

والإيميلات بتتفد Payment provider calls queued workflows. usage ولا [app/Jobs](#) لكن مغيث، queue tables/config فيه inline.

:Root Cause

MVP implementation بدون async boundary.

:Technical Impact

Requests هتفضل مرتبطة بزمان provider/mail، ومغيث retries منظمة.

:Business Impact

Checkout latency أعلى وفشل مؤقت يتحول لفشل مستخدم نهائي.

:Recommended Solution

انقل email sending, payment reconciliation, cleanup وnotifications ل jobs.

:Implementation Guidance

Supervisor/Horizon-like process. ب workers managed و، retry/backoff, failed job monitoring, [ShouldQueue](#) استخدم

:Estimated Fix Effort

Medium

:Priority

Short-Term

Finding ID: AUD-032

:Severity

Medium

:Category

File Delivery / Reliability

:Location

Download streaming

:File

app/Http/Controllers/DownloadController.php

:Line

65-82

:Issue Title

Manual file streaming fragile ومش بيستخدم Storage API بشكل كامل

:Problem Description

lazy relation فشل، وفيه `fopen` لو handling مفيش. `file_exists`, `fopen`, `fread`, `flush` ويستخدم absolute path الكود بيطلع access `$download->order->ebook`.

:Root Cause

File delivery معمول يدوي بدل response framework/storage.

:Technical Impact

Warnings/partial downloads ونقاط فشل مش مغطيه، واحتمال N+1 لو اتوسع.

:Business Impact

تجربة تحميل غير مستقرة ودعم أعلى.

:Recommended Solution

error handling آمن مع streamed response أو `Storage::disk("local")->download()` استخدم.

:Implementation Guidance

failure sanitized وسجل، `disk` عبر `check existence` ل `order.ebook` ل eager load اعمل.

:Estimated Fix Effort

Medium

:Priority

Short-Term

Error Handling Audit

Error handling الحالي مش موحد، وفيه exception messages بتطلع للعميل. كمان logging يا إما زيادة وخطر في webhook يا إما ناقص في payment/admin operations.

Finding ID: AUD-028

:Severity

Medium

:Category

Observability / Audit Logging

:Location

Payment/admin operations

:File

:Line

99-109 ,45-55

:Issue Title

مفیش audit trail للأفعال الحساسة

:Problem Description

إنشاء/تعديل/حذف ebooks، payment initiation، webhook paid transition، download events، وaudit logs مفیهاش آمنة ومهیكله.

:Root Cause

Logging یا إما debug secrets فی webhook یا إما مش موجود فی باقي flows.

:Technical Impact

صعب تعرف مین غیر إیه أو تشخص fraud/support cases.

:Business Impact

Security team وsupport هیواجهوا صعوبة فی التحقیقات.

:Recommended Solution

ضیف audit events/logs sanitized للأفعال الحساسة.

:Implementation Guidance

سجل admin user id، action، resource id، order id، provider transaction id، من غیر secrets أو PII زیاده.

:Estimated Fix Effort

Medium

:Priority

Short-Term

Testing Audit

التستات الحالية مش بتغطی أي business/security behavior حقیقی. نجاح test suite الحالي misleading لأنه یقیس scaffold فقط.

Finding ID: AUD-022

:Severity

High

:Category

:Location

Test suite

:File

tests/Feature/ExampleTest.php

:Line

13-17

:Issue Title

Test suite عبارة عن scaffold tests فقط

:Problem Description

php artisan test 2 يبعدي tests بوحدة واحدة لل / بوحدة tests ببعدي 2 php artisan test true is true بس: واحدة لل / بوحدة tests ببعدي 2 php artisan test auth, orders, payments, webhooks, downloads, admin authorization, validation, أو security.

:Root Cause

مفیش testing strategy لل backend domain.

:Technical Impact

أي regression في payment/security ممكن يعدي CI لو موجود.

:Business Impact

مخاطر production incidents عالية جدا.

:Recommended Solution

ابني feature/unit test suite حول أعلى flows خطورة.

:Implementation Guidance

ابدأ بـ Paymob HMAC, amount mismatch, admin access, duplicate purchases, download ownership, and validation/rate limiting.

:Estimated Fix Effort

High

:Priority

Immediate

Dependency Audit

composer.json valid وplatform requirements لكن security audit إنه لقي advisories فشل بمعنى إنه لقي security audit ناجحة، و direct outdated

DevOps & Production Readiness Audit

قيم محلية `.env` active في. production contract وناقص `local-biased` `.env.example`. Docker/CI/CD/deployment manifests مغيث قبل CI gate وdeployment checklist لازم يتعمل. `database-backed queue/cache` و`MAIL_MAILER=log`, `APP_DEBUG=true` زي production.

Finding ID: AUD-025

Severity

Medium

Category

DevOps / Delivery

Location

Project root

File

N/A

Line

N/A

Issue Title

مغيث Docker/CI/CD/deployment files واضحة

Problem Description

deploy manifests أو `.github/workflows`, `.gitlab-ci.yml`, `docker-compose`, `Dockerfile` الفحص ملقاش

Root Cause

مشروع backend لسه مغيثوش delivery automation ظاهرة في repo.

Technical Impact

مغيث automated checks للتستات، build، migrations، composer audit، Pint، أو deploy repeatability.

Business Impact

Deployments يدوية ومعرضة للأخطاء، وصعب تعمل compliance evidence.

Recommended Solution

ضيف CI pipeline وdocs container/deploy حسب بيئة الاستضافة.

:Implementation Guidance

release في pipeline: install deps, validate composer, run Pint, tests, composer audit, npm build, cache config/routes
.step

:Estimated Fix Effort

Medium

:Priority

Short-Term

Finding ID: AUD-026

:Severity

Medium

:Category

Environment / Configuration

:Location

Environment example and active env

:File

env.example.

:Line

1-73

:Issue Title

env.example local-biased وناقص production/security keys

:Problem Description

env.example APP_DEBUG=true, APP_ENV=local, MAIL_MAILER=log, SESSION_ENCRYPT=false وفيه Paymob/Sanctum ومفيعوش
production keys المطلوبة.

:Root Cause

Environment contract مش موثق كفاية لـ production.

:Technical Impact

Deploy ممكن يطلع ناقص secrets أو بإعدادات dev.

:Business Impact

فشل email/payment أو تسريب debug details لو اتنسخت القيم.

:Recommended Solution

:Implementation Guidance

ضعيف PAYMOB_API_KEY, PAYMOB_HMAC_SECRET, PAYMOB_INTEGRATION_ID, SANCTUM_STATEFUL_DOMAINS, SESSION_SECURE_COOKIE, LOG_LEVEL, queue/cache drivers.

:Estimated Fix Effort

Low

:Priority

Immediate

Top 20 Security Issues

1. `storage/{path}` routes في runtime ظاهرة رغم private storage intent.
2. `logs` يتسجلوا في payment payload و `hmac_secret`.
3. Payment amount يتحسب من ebook price الحالي بدل order snapshot.
4. Webhook مش يتحقق من amount/currency/integration/refund/void flags.
5. `composer audit --locked` 9 لقي advisories.
6. مفيش route-specific throttling على auth/public write/payment endpoints.
7. `User` fillable بيسمح `role` و `email_verified_at`.
8. `RegisterRequest` بيقبل `role` من العميل.
9. Seeded admin/user credentials ضعيفة.
10. `load-test.js` فيه credentials hardcoded.
11. Admin order resource routes غير implemented.
12. Ebook delete بيعمل cascade على paid orders.
13. Sanctum token abilities مش scoped في login/register.
14. Webhook processing مش transactional.
15. Missing unique provider transaction constraints.
16. Contact form معرض لـ spam/large payloads.
17. Download tokens reusable طول فترة expiry.
18. Session secure/encrypted production policy مش موثقة.
19. Exception messages بتطلع للعميل.
20. مفيش centralized audit trail للأفعال الحساسة.

Top 20 Performance Issues

- 1.1. Paymob HTTP calls بدون timeout.
- 2.2. Paymob HTTP calls بدون retry/backoff.
- 3.3. Checkout synchronous بالكامل.
4. 4. `dashboard/purchases` غير paginated.
5. 5. `messages` غير paginated.
6. 6. Missing index على `orders.paymob_order_id`.
7. 7. Missing index على `orders(user_id, status, created_at)`.
8. 8. Missing index على `ebooks(is_published, created_at)`.
9. 9. Missing index على `downloads(user_id, expires_at)`.
10. 10. Missing index على `contact_messages(is_read, created_at)`.
- 11.11. Manual PDF streaming بدل optimized storage responses.
- 12.12. Lazy relation access في download streaming.
- 13.13. Database cache store ممكن يبقى bottleneck.
- 14.14. Database queue store بدون workers/monitoring واضح.
- 15.15. مفيش caching لـ public ebook listings.
- 16.16. مفيش query scopes منظمة.
- 17.17. Admin filters غير validated وممكن تعمل inefficient queries مستقبلا.
- 18.18. File upload flow مفهوش async scan/processing.
- 19.19. No load-test integration في CI.
- 20.20. No observability metrics لـ payment/download endpoints.

Top 20 Refactoring Opportunities

1. 1. `CheckoutService` لإنشاء orders وتثبيت amount snapshot.
2. 2. `PaymentInitiationService` لفصل provider calls.
3. 3. `PaymobWebhookProcessor` transactionally للتحقق والتحديث.
4. 4. `DownloadTokenService` واضحة token بسياسة.
5. 5. `EbookManagementService` لـ upload/delete/archive.
- 6.6. Controller لـ email verification بدل route closure.
- 7.7. API Resources موحدة لكل responses.
- 8.8. Policies متوصلة فعليا بدل checks يدوية.
9. 9. Enums/Casts لـ `OrderStatus` و `UserRole`.
- 10.10. Query scopes لـ paid/pending/published filters.

11.11. FormRequests لكل admin filters/uploads.

12.12. Centralized JSON error renderer.

13.13. Audit logging service للأفعال الحساسة.

14.14. Jobs للـ emails/reconciliation/cleanup.

15.15. Soft delete/archive للـ ebooks.

16.16. Money ValueObject للـ cents conversion.

17.17. Remove or gate dev seeders.

18.18. Move load testing config to env variables.

19.19. Separate formatting-only cleanup commit.

20.20. Add CI quality gates.

Database Optimization Recommendations

- بعد تنظيف البيانات القديمة `orders.paymob_order_id` على unique index ضيف.
 - مضمون provider transaction unique لو `orders.paymob_transaction_id` على unique index ضيف.
 - order واحد لكل token هو business rule لو `downloads.order_id` على unique index ضيف.
 - `orders(user_id, status, created_at)` على composite index ضيف.
 - `orders(paymob_order_id)` على index ضيف لـ webhook lookup.
 - `ebooks(is_published, created_at)` على composite index ضيف.
 - `downloads(user_id, expires_at)` على composite index ضيف.
 - `contact_messages(is_read, created_at)` على composite index ضيف.
- راجع cascade delete واستبدله بـ restrict/soft delete للـ financial records.
- خزن order snapshots كافية: ebook title, author, price, currency وقت الشراء.

API Consistency Recommendations

- موحد response envelope استخدم: `data, meta, links, message, errors`.
 - `JsonResource` بدل raw models/arrays استخدم.
 - validation للإنشاء، 204 للحذف، 409 للتكرار، 422 للـ status codes: 201 وحّد.
- طبّق pagination على كل list endpoints.
- validation للـ filters/sorts/per_page اعمل.
- وثّق API بـ OpenAPI/Swagger.
- route names واضحة لكل endpoints اعمل.
- throttling حسب نوع endpoint طبّق.
- افصل public/admin/user resources عشان field exposure يبقى واضح.

Immediate Action Plan

1. 1. cache rebuild بعد route:list وتأكد من storage runtime exposure اقل.
- 2.2. شيل secret/full payload logging من Paymob webhook.
3. 3. payment initiation في orders.amount استخدم.
- 4.4. تحقق من Paymob webhook invariants قبل marking paid.
- 5.5. حدّث vulnerable dependencies وشغلّ audit تاني.
- 6.6. طبقّ rate limiting على auth/contact/payment/download routes.
7. 7. شيل role وemail_verified_at من public mass assignment paths.
- 8.8. امنع seed demo accounts من production.
- 9.9. أصلح admin order routes غير implemented.
- 10.10. ابدأ test suite لل critical flows.

Day Improvement Plan-30

- 1.1. ابني services/actions لل checkout/payment/webhook/download.
- 2.2. أضيف DB constraints/indexes بعد data review.
- 3.3. طبقّ API resources وconsistent response envelope.
- 4.4. أضيف centralized exception handling وrequest IDs.
- 5.5. أضيف CI pipeline ل tests, Pint, composer audit.
- 6.6. أضيف queue jobs لل emails/reconciliation/cleanup.
- 7.7. وثّق production env contract.
- 8.8. أضيف audit logs sanitized للأفعال الحساسة.
- 9.9. اعمل OpenAPI documentation.
- 10.10. نفذ soft delete/archive لل ebooks.

Day Improvement Plan-90

- 1.1. Monitoring/alerting كامل لل API/payment/queues.
- 2.2. Security regression suite لل auth/webhooks/downloads.
- 3.3. Performance/load testing pipeline.
- 4.4. Deployment automation وrollback strategy.

5.5. Payment reconciliation dashboard/job.

6.6. Access review لا admin operations.

7.7. Data retention policy لا orders/downloads/logs.

8.8. Dependency update cadence شهري.

9.9. Threat model رسمي لا checkout/download flows.

10.10. Incident response runbook.

Final Scores

Architecture Score (4/10)

الهيكل الأساسي Laravel واضح، لكن business logic متكدس في controllers/routes، وفيه refactor جزئي غير مكتمل لا policies/resources. مفيش service layer كافي غير Paymob/Download، ومفيش boundaries واضحة لا checkout/payment.

Security Score (3/10)

فيه مشاكل حرجة في webhook logging، payment integrity، dependency advisories، rate limiting، mass assignment و runtime storage routes. بعض التحسينات بدأت تظهر في worktree لكنها مش مكتملة ولا مثبتة بتستات.

Performance Score (4/10)

الاستعلامات بسيطة حالياً، لكن مفيش indexes كفاية، فيه endpoints غير paginated، و Paymob calls synchronous بدون timeout/retry. الأداء هيصعف بسرعة مع نمو البيانات.

Code Quality Score (4/10)

Pint فشل على ملفات كثير، وفيه mixed comments/style و raw arrays بدل resources، لكن الكود صغير ومفهوم كبداية MVP.

Maintainability Score (4/10)

غياب tests حقيقية و centralized error handling و API resources بيخلي أي تعديل عالي المخاطر. وجود partial untracked refactor و بيزود الغموض.

Scalability Score (3/10)

مفيش jobs فعلية، queue/cache defaults مش production-grade، ولا CI/CD أو Payment/download deployment artifacts. flows مش مصممة لتحمل latency أو concurrency.

Production Readiness Score (2/10)

Dependencies فيها env template dev-biased، advisories، مفيش scaffold-only tests، CI/CD، ومفيش monitoring/audit trail. لا

يُنصح بإطلاق production قبل remediation.

Overall Score (3/10)

المشروع مناسب ك MVP/learning backend، لكنه مش جاهز production بسبب security/payment/testing/deployment gaps الأساسية.